

Capítulo 2

Introdução ao Teste de Invasão e Ética Hacker

2.1. Objetivos:

- Fornecer ao aluno uma visão geral sobre testes de invasão
- Entender a anatomia e os tipos diferentes de ataques
- Conhecer as fases de um teste de invasão
- Conhecer as metodologias e os aspectos legais

2.2. Visão geral sobre o Pentest

O Teste de Intrusão é um processo de análise detalhada do nível de segurança de um sistema ou rede usando a perspectiva de um infrator. Trata-se de um teste realista ao nível de segurança das infra-estruturas e da informação que estas detêm. No Teste de Intrusão são testadas vulnerabilidades técnicas e conceituais das infra-estruturas alvo.

O objetivo principal é simular de forma controlada um ataque real que normalmente é executado por criminosos. Desta maneira é possível ter o conhecimento total do que poderia acontecer caso esse ataque realmente existisse, garantindo assim a possibilidade de uma estratégia de prevenção.

2.3. Tipos de Pentest

2.3.1. Blind

Nessa modalidade o auditor não conhece nada sobre o alvo que irá atacar, porém o alvo sabe que será atacado e o que será feito durante o teste.

O grande risco desse tipo de teste, é que o alvo pode avisar a equipe de TI e decidirem fazer atualização do sistema, aplicar patches de correção e segurança. Esse tipo de pentest é interessante para ter conhecimento de como e quais informações sobre a organização e sua infraestrutura é possível de um atacante ter acesso.

2.3.2. Double blind

Nessa modalidade o auditor não conhece nada sobre o alvo, e o alvo não sabe que será atacado e tão pouco sabe quais testes o auditor irá realizar.

É o método de pen test mais realista possível, aproximando-se de um ataque real, pois ambas as partes, auditor e alvo, não sabem com o que irão se deparar. Afinal, em um ambiente real, o atacante não sabe nada inicialmente sobre seu alvo, e o alvo nunca saberá qual tipo de ataque um cracker pode realizar contra sua

infraestrutura.

2.3.3. Gray Box

Nessa modalidade o auditor tem conhecimento parcial do alvo, e o alvo sabe que será atacado e também sabe quais testes serão realizados.

Aproxima-se de um teste onde é simulado o ataque de dentro de um ambiente completamente monitorado e controlado.

2.3.4. Double Gray Box

Nessa modalidade o auditor tem conhecimento parcial do alvo, e o alvo sabe que será atacado, porém, não sabe quais testes serão executados.

Esse é o melhor método para simular um ataque partindo de um funcionário insatisfeito, que possui privilégios de usuário, por exemplo, e procura realizar escalada de privilégios para ter acesso às informações que seu nível ou grupo não possui.

2.3.5. Tandem

Nessa modalidade o auditor tem total conhecimento sobre o alvo, o alvo sabe que será atacado e o que será feito durante o ataque. Também conhecido como “caixa de cristal”.

Esse tipo de pen test é bem próximo de uma auditoria, pois ambos estão preparados e sabem o que vai ser realizado. É o ideal para ser feito periodicamente, monitorando as vulnerabilidades novas e mudanças feitas na infraestrutura.

2.3.6. Reversal

Nessa modalidade o auditor tem conhecimento total do alvo, porém o alvo não sabe que será atacado, e tão pouco sabe quais testes serão executados.

Esse formato de teste é ideal para testar a capacidade de resposta e como está o timing de ação da equipe de resposta a incidentes do alvo.

2.4. As fases de um ataque

Um ataque, ou teste de invasão, é composto por uma série de fases, onde em cada uma determinadas operações são realizadas.

O que vai definir a diferença de um teste de invasão e um ataque realizado por um cracker, são justamente a intenção, o escopo e o espaço de tempo disponível para o mesmo.

As fases básicas de um ataque são explicadas a seguir.

2.4.1. Levantamento de Informações

Essa é a fase mais importante de um ataque e de um teste de invasão.

Baseado no que é descoberto nessa fase, todo o planejamento é realizado e os vetores de ataque definidos. Essa fase prossegue na fase seguinte, onde as informações iniciais são extendidas, de forma mais detalhada.

Podemos dizer que essa é a fase abrangente, e a fase seguinte detalha as informações adquiridas nessa primeira fase.

Qualquer informação que seja vinculado ao alvo é considerada de valor nesse primeiro passo:

- Concorrentes
- Nome de funcionários
- Endereços
- Telefones
- Sites

- Empresas
- Comunidades sociais
- Empresas do mesmo grupo e etc.

2.4.2. Varredura

Nessa fase o atacante busca informações mais detalhadas o alvo, que posam permitir definir seus vetores de ataque e enxergar as possibilidades que podem permitir ganhar acesso ao sistema, através da exploração de alguma falha encontrada.

Aqui buscamos informações que respondam algumas perguntas, como por exemplo:

- Qual sistema operacional o alvo utiliza?
- Quais os serviços estão sendo executados no alvo?
- Quais serviços estão disponíveis para acesso?
- Qual a versão de cada serviço sendo executado?
- Há IDS/IPS na rede?
- Há honeypots na rede?
- Há firewalls na rede?
- Existe uma rede interna e outra externa, como uma DMZ?
- Há serviços com acesso público rodando em alguma máquina?
- Há algum software malicioso já sendo executado em alguma máquina?

A partir dessas informações, o atacante pode buscar maiores detalhes na internet ou fóruns especializados em busca de exploits que permitam explorar falhas existentes nas versões dos serviços sendo executados.

2.4.3. *Ganhando acesso*

Aqui o atacante coloca em prática tudo aquilo que planejou a partir das informações obtidas previamente.

Dependendo de seus vetores de ataque, ele pode realizar uma série de ataques buscando ganhar acesso ao sistema alvo, como por exemplo:

- Ataques de força bruta local
- Ataques de força bruta remoto
- Captura de tráfego de rede
- Ataque de engenharia social
- Ataques às aplicações WEB
- Exploração de serviços
- Exploração de sistema operacional

Conseguindo acesso ao sistema, o atacante realizará uma série de operações buscando a elevação de seus privilégios caso o mesmo já não seja de root.

2.4.4. *Mantendo acesso*

Após conseguir o acesso, o atacante busca, de alguma forma, manter o acesso conseguido através de seus ataques. Isso normalmente não é utilizado por um pen tester, a não ser que seja extremamente necessário.

O risco de configurar o sistema, implantando backdoors ou outro tipo de dispositivo que permita o acesso posterior, é que a ferramenta utilizada pode voltar-se contra você, pois outras pessoas podem descobri-la, explorá-la e ganhar acesso facilmente ao sistema comprometido.

Portanto, essa fase, quando realizada durante um teste de invasão, precisa de extremo cuidado e planejamento para não trazer comprometimentos e prejuízos

desnecessários ao alvo.

2.4.5. Limpando rastros

Nessa fase final do ataque, o atacante apaga todos os seus rastros, todos os registros de operações realizadas dentro do sistema comprometido.

Como o pen tester tem autorização para realizar os testes, não é necessário apagar rastros. Isso se torna importante para um pen tester, apenas se quiser testar, também, a capacidade da equipe de perícia forense e respostas a incidentes de descobrir o que foi feito e recuperar informações alteradas.

2.5. Categorias de ataques

Há vários tipos de ataque possíveis de serem realizados. Podemos dividir tais ataques em dois grandes grupos:

2.5.1. Server Side Attacks

Server Side Attack ou ataque ao servidor foca na tentativa de explorar serviços que estão em execução em um determinado dispositivo. Normalmente não precisam de interação do usuário e provê uma Shell remota para o atacante.

- São exemplos de ataques a servidores:
- Ataques a servidores WEB
- Ataques a servidores de e-mail
- Ataques a servidores DNS
- Ataques a serviços RPC

2.5.2. Client Side Attacks

Client Side Attacks ou ataques ao cliente foca na tentativa de explorar aplicações que são executadas no computador e que normalmente precisam de uma interação da pessoa para que o ataque seja executado.

São exemplos de ataques ao cliente:

- Exploração de falhas no Internet Explorer
- Exploração de falhas em editores de texto
- Exploração de falhas em Clientes de E-mail
- Exploração de falhas em programas reprodutores de vídeo

Nesses casos, o cliente precisa visitar um site, ou abrir um e-mail, ou então abrir um arquivo que explorará a aplicação que está instalada no computador do cliente.

Packs como Mpack e IcePack exploram vulnerabilidades em navegadores webs, ou seja, realizam um client side attack.

2.6. Metodologias existentes

Para um teste de invasão não ficar “solto” e sem uma sequência lógica coerente, a comunidade de segurança, através de alguns órgãos, associações, institutos e pesquisadores, criou uma série de metodologias para servirem como guias básicos para a correta realização de testes de invasão.

Isso permite uma certa padronização nos testes realizados seguindo uma outra metodologia. Podemos citar as seguintes metodologias conhecidas internacionalmente:

- OSSTMM
- OWASP Testing Guide

- NIST SP800-115 e SP800-42
- ISSAF
- PenTest Frameworks

Nosso treinamento foi feito baseado na metodologia OSSTMM (Open Source Security Testing Methodology Manual), e nessa metodologia as premissas para realizar um teste são:

- O teste dever ser conduzido exaustivamente
- O teste deve contemplar todos os itens necessários
- O escopo do teste não deve ferir os direitos humanos básicos
- Os resultados devem ser quantificáveis
- Os resultados devem ser consistentes
- Os resultados devem conter apenas o que foi obtido com os testes

Essas são as premissas de um teste de intrusão. Ainda em acordo com a OSSTMM, o resultado final deve conter os seguintes tópicos:

- Data e hora dos testes
- Tempo de duração dos testes
- Analistas e pessoas envolvidas
- Tipo do teste
- Escopo do teste
- O resultado da enumeração
- Margens de erro
- Qualificação do risco
- Qualquer tipo de erro ou anomalia desconhecida



Dica: a metodologia OSSTMM é voltada mais para testes em sistemas e infraestrutura, apesar de também contemplar testes em aplicações WEB. A metodologia desenvolvida pelo OWASP, já é específica para testes de invasão em aplicações WEB.

2.7. Como conduzir um teste de invasão

Alguns passos básicos são necessários para a preparação e realização de um teste de invasão, para que o mesmo seja bem sucedido. Dentre esses passos, ou fases, podemos destacar os seguintes:

Passo 1: Converse com seu cliente sobre as necessidades do teste;

Esse é um dos passos mais importantes, pois não podemos deixar que existam “zonas cinza” no que foi contratado e acertado, entre o cliente e o pen tester. Aqui definimos tudo, desde o escopo, ao tipo de teste que será realizado. Aqui também é definido o que é permitido e o que não é permitido realizar durante o teste.

Passo 2: Prepare o contrato de serviço e peça ao cliente para assiná-los;

Depois de tudo definido no primeiro passo, é feito um contrato de prestação de serviço, onde está descrito o que será realizado (escopo, horários, equipe de profissionais, permissões, etc) e assinado por contratado e contratante.

Além de um contrato de prestação de serviço, é de grande importância a assinatura de um NDA (non disclosure agreement), que define que as informações que a equipe do teste de invasão terá acesso, não serão revelados ou divulgados, excetuando-se à pessoa que assinou o contrato de prestação de serviço.

Passo 3: Prepare um time de profissionais e agende o teste;

Aqui reunimos os profissionais que participarão dos testes e lhes passamos todas as informações pertinentes ao que será realizado.

A partir da formação da equipe e definição de papéis para cada profissional, podemos agendar o teste com o cliente e iniciar o planejamento do mesmo com a equipe em conjunto.

Passo 4: Realize o teste;

Nesse passo é onde o teste é efetivamente executado. Lembrando sempre de seguir o que foi acordado com o cliente e respeitar as cláusulas do contrato e NDA assinados.

Passo 5: Analise os resultados e prepare um relatório;

Todas as informações coletadas, resultados obtidos e ocorrências durante a realização do teste são posteriormente reunidas e analisadas. Os resultados dessas análises são colocados em um relatório, contextualizados, e é feita a descrição, explicação e possível solução para cada falha encontrada e explorada.

Passo 6: Entregue o relatório ao cliente.

O relatório pós-teste, é entregue APENAS para a pessoa responsável pela contratação do teste de invasão, ou definida em contrato.

Como as informações contidas em tal relatório são extremamente sensíveis, deve-se tomar o máximo cuidado possível para que o mesmo não caia nas mãos de pessoas sem autorização para ter acesso ao mesmo. O ideal é que a equipe não guarde nem mesmo uma cópia do relatório, e isso deve ser definido no NDA e no contrato de serviço.

Essa medida extrema é tomada justamente para evitar qualquer vazamento possível de informações.

2.8. Aspectos Legais

É importante atentarmos para os aspectos legais de um teste de invasão, e se os mesmo estão de acordo com as leis vigentes no país, e principalmente com o que foi assinado no contrato de prestação de serviço ou NDA.

Devemos lembrar-nos de uma coisa:

TESTE DE INVASÃO SEM PERMISSÃO É CRIME!

Portanto, tenha sempre um contrato prévio assinado com o cliente, onde serão definidos os seguintes pontos:

- Limites do teste: até onde pode ir;
- Horários: períodos de menor utilização ou menos críticos;
- Equipe de suporte: caso haja alguém para tomar providências caso alguém ataque tenha efeitos colaterais;
- Contatos: ao menos três contatos, com e-mail, endereço e telefone;
- Permissão assinada: um documento assinado pelo responsável pela empresa, com os nomes das pessoas da equipe autorizadas a realizar os testes.

Dentro do que foi acordado, devemos ter o máximo cuidado para não causar comprometimentos que tragam algum tipo de prejuízo ao cliente, como a indisponibilidade de informações vitais para o funcionamento organizacional, por exemplo.

Levando em conta esse aspecto, se possível, é interessante reproduzir o ambiente de testes em máquina virtual para aproximar-se do possível comportamento do ambiente testado antes de finalmente lançarmos alguns tipos de ataques.

Isso evitaria a maior parte dos comprometimentos não planejados à infraestrutura do cliente, e pode poupar muita dor de cabeça!

2.9. Exercícios teóricos

1 - Qual o objetivo da OSSTMM?

2 - Qual a necessidade da utilização de uma metodologia para realizar um teste de invasão?

3 - Cite algumas publicações especiais da NIST que poderiam ser utilizadas para a realização de um teste de invasão.

4 - Quais as fases de um ataque?

Capítulo 3

Escrita de Relatório

3.1. Objetivos

- Entender o que é um relatório
- Aprender o que deve conter em um relatório de teste de invasão
- Desenvolver um modelo básico de relatório de teste de invasão

3.2. O que é um relatório?

Um relatório é um conjunto de informações, utilizado para reportar resultados parciais ou totais de uma determinada atividade, experimento, projeto, ação, pesquisa, ou outro evento, esteja finalizado ou ainda em andamento.

No caso de um teste de invasão, é necessário gerarmos um relatório final contendo todos os passos realizados, comandos e programas utilizados, além dos resultados obtidos e a avaliação dos mesmos.

3.3. O que deve conter no relatório

A estrutura básica de um relatório de teste de invasão deve respeitar, ao menos, os seguintes tópicos:

- **Capa**

Onde deve estar presente o nível de confidencialidade do documento. Deve apresentar também o nome do contratado e do contratante. Outra informação importante é o nome da pessoa ao qual o relatório está sendo endereçado, sendo o representante da contratante como exposto no contrato de prestação de serviços.

- **Índice**

Facilitará a compreensão das seções existentes no relatório e possibilitará a busca posterior por tópicos específicos constantes no relatório. Deve ser o mais detalhado possível.

- **Classificação do nível de confidencialidade do documento**

Nesta seção é importante citar novamente o nível de confidencialidade do

documento, destacando a quem o documento está endereçado, com posterior assinatura do representando do contratante e do contratado.

- **Sumário executivo**

No sumário executivo contextualizamos todo o teste de invasão, definindo os horários de realização dos testes, as necessidades do teste de invasão apresentadas pelo contratante, o retorno de investimento que um pen test pode trazer para a empresa e etc.

- **Definição do escopo**

Na definição de escopo é onde descrevemos o tipo e o nível do teste realizado, descrevendo o que foi e até onde foi testado. Aqui, nos baseamos nas permissões que recebemos do contratante, de até onde podemos ir e o que podemos fazer.

- **Definição dos vetores de ataque**

Aqui entra o mapa mental que criamos com os possíveis vetores de ataque e o planejamento para cada possibilidade. Definimos também as várias possibilidades de ataque, classificando-as de acordo com o nível de facilidade para alcançar o objetivo definido no escopo do teste.

Outro aspecto que entra nessa seção são os resultados obtidos com o mapeamento da rede e a definição dos alvos.

- **Ataques realizados**

Na definição dos ataques realizados, várias informações devem estar contidas nessas definições. São elas:

- ✓ Ferramentas utilizadas

- ✓ Exploits executados
- ✓ Comandos utilizados
- ✓ Resultados recebidos
- ✓ Classificação das vulnerabilidades por nível de facilidade de exploração, popularidade, impacto, e tirando a média desses 3, informando o risco.

- **Solução**

Essa última seção é onde informamos possíveis soluções para as vulnerabilidades encontradas.